

Data protection — Law N° 058/2021 (Rwanda)

RwaSport processes the personal data of children. That is the fact that shapes everything below: most Amashuri Games athletes are schoolchildren, and the platform holds their dates of birth, identity references, class, student code, a parent or guardian's phone number, and — where relevant — disability information.

The governing law is **Law N° 058/2021 of 13/10/2021 relating to the protection of personal data and privacy**, in force since 15 October 2021. The supervisory authority is the **National Cyber Security Authority (NCSA)**; the Data Protection and Privacy Office publishes guidance at dpo.gov.rw. Full text: [RISA · RwandaLII](#).

This document is the record of processing activities the law requires (art. 17), the retention schedule (art. 52), the breach procedure (arts. 43–45), and an honest list of what is **not yet compliant**.

1. Record of processing activities (art. 17)

Controller. RwaSport / Rwanda National Sports Platform, operated under the Ministry of Sports. Data protection contact: privacy@rwasport.rw.

ACTIVITY	DATA	SUBJECTS	LAWFUL BASIS (ART. 46)	RECIPIENTS	RETENTION
Athlete registration (Amashuri)	Name, DOB, nationality, gender, class, student code, guardian name + phone, ID reference, disability where declared	Schoolchildren, mostly under 18	Guardian consent (art. 9) + public-interest duty of organising school sport	School coordinator, Amashuri admins, Ministry	Season records; erased on request
Player registration (leagues)	Name, DOB, nationality, ID/passport reference, position, photo	Adult and youth players	Contract with club; public-interest duty	Club, federation, league admins	Season records
Document verification	Birth certificate, national ID, passport, medical records	Players and athletes	Legal/competition obligation	Verifying admins only	Until verification concludes
Accounts and authentication	Name, username, email, phone, password hash, refresh tokens	Staff, coordinators, managers	Contract	Platform admins	Life of account; tokens 30 days
Audience measurement	IP address, user agent, page path, session id	Site visitors	Legitimate interest	Platform admins	90 days
Administrative audit trail	Actor, action, target, IP	Staff	Legal obligation; accountability	Superadmins	365 days
Contact enquiries	Name, email, message	Public	Consent	Admins	365 days
Data-subject requests	Name, contact, request details	Any data subject	Legal obligation (arts. 18–24)	Superadmins	730 days after closure
Payments	Name, contact, transaction reference	Subscribers	Contract	Flutterwave (processor)	Per financial law

Sensitive data (art. 3(2)). Disability information (`AkcPlayer.hasDisability` , `disabilityType`) is health data. Medical documents uploaded for verification are medical records. Both are restricted to the roles that perform the duty they were collected for and are never returned on a public endpoint.

Children (art. 9). An athlete under 16 is registered only when the roster form records a parent or guardian's name and an explicit `guardianConsent = YES` . Rows without it are refused, so no child's record exists without a stated basis. An athlete whose age is unknown is treated as a child.

2. What the public can see

The rule: publishing a fixture, a result or a team sheet needs a name, a shirt number and a position. It never needs a date of birth, a national ID, a guardian's phone number, a student code or a disability.

Enforced centrally in `apps/backend/src/services/privacy.service.ts` (`PUBLIC_ATHLETE_SELECT`, `PUBLIC_PLAYER_SELECT`, `redactPlayer`). Endpoints that show more to a privileged caller use the `attachUser` middleware, which identifies a signed-in user without rejecting the public.

ENDPOINT	ANONYMOUS	PRIVILEGED
<code>GET /akc3/athletes</code>	401	Amashuri admins only
<code>GET /akc3/schools/:id</code>	Name, gender, age category, position, jersey	Full record for Amashuri admins and that school's coordinator
<code>GET /players/:id</code>	No DOB, ID number, height, weight or documents	Full record for verification roles
<code>GET /akc3/school/*</code>	403	Scoped to the coordinator's own school

3. Retention (art. 52)

Periods are declared once, in `RETENTION_DAYS` in `privacy.service.ts`, and enforced by `scripts/purge-expired-data.mjs`.

```
npm run privacy:purge      # dry run – shows what is past its period
npm run privacy:purge:apply # delete it
```

Run this daily on a schedule. Until it does, page-view rows carrying visitors' IP addresses accumulate indefinitely, which art. 52 does not permit.

Athlete and player records are deliberately excluded: they belong to the seasons they were part of and are removed through an erasure request, not a timer.

4. Data-subject rights (arts. 18–24)

Every right carries a **30-day** deadline from receipt.

- `POST /api/v1/privacy/requests` — unauthenticated, because the people most likely to use it are parents and guardians who have no account. It opens a case and returns only a reference and the deadline; it never discloses personal data.
- `GET /api/v1/privacy/me/export` — a signed-in user downloads their own record in structured JSON, satisfying arts. 18 and 20 immediately.
- `GET /api/v1/privacy/requests?overdue=true` — superadmin register; each row carries `daysRemaining` and `overdue`.

- `PATCH /api/v1/privacy/requests/:id` — progress a request; closing it stamps `closedAt` and writes to the audit log.

Verify identity out of band before disclosing or erasing anything. The endpoint cannot do this, and disclosing a child's data to the wrong "parent" is a breach.

5. Breach procedure (arts. 43–45)

WHEN	WHAT	TO WHOM
Within 48 hours of becoming aware	Notify the breach	NCSA
Within 72 hours	Full report: nature, categories and approximate number of subjects, likely consequences, measures taken	NCSA
Without undue delay, where risk is high	Inform the affected people directly	Data subjects

A processor that becomes aware of a breach must tell the controller within 48 hours.

On discovering a breach: contain it; preserve logs (`ActivityLog` records actor, action and IP); establish which categories and how many people are affected; start the 48-hour clock from the moment of awareness, not the moment of confirmation; record everything in the incident log. A breach involving children's data is high-risk by default.

6. Outstanding

Each item says what the platform now does on its own, and what still needs a human.

This section is also live in the product. Super Admin → Data Protection (`/admin/compliance` , `GET /privacy/compliance`) reports the same obligations as a current reading: the consent backlog, open and overdue data-subject requests, and rows held past their retention period are *counted from the database*, not copied from here, so they change without anyone editing this file. The obligations that need a person — registering, appointing, signing — are reported as configuration: set, or not set. A checklist that implied work nobody had done would be worse than no checklist.

6.1 Storage outside Rwanda (arts. 48 and 50) — highest risk

`.env.example` documented production on Supabase `aws-0-eu-central-1` — **Frankfurt** — and nothing in the code noticed. Media goes to Cloudinary and the frontend to Vercel, both offshore.

Now enforced. `DATA_RESIDENCY` and `NCSA_REGISTRATION_NUMBER` are declared configuration, checked at boot by `dataResidency.service.ts` . In production the server **refuses to start** when personal data would sit offshore without a declared certificate, and refuses a declaration of `rwanda` that contradicts the configured host. Outside production the same problems warn rather than block.

Still needed. A configuration check cannot make an offshore deployment lawful. Host in Rwanda, or obtain the NCSA certificate and execute written processor contracts. See `privacy/PROCESSORS.md`. Setting `STORAGE_DRIVER=local` removes one offshore processor — verification documents — immediately.

6.2 Registration with the supervisory authority (art. 29)

Prepared. The record of processing in §1 is most of the application; what each field needs and where it already exists is mapped in `privacy/DPO-AND-REGISTRATION.md` Part 2.

Still needed. A named DPO, a decision on transfers, and the filing itself. The certificate this produces is the same one art. 50 requires above.

6.3 Data Protection Officer (art. 40)

Prepared. Terms of reference, a first-90-days list and an appointment checklist: `privacy/DPO-AND-REGISTRATION.md` Part 1.

Still needed. A person. `privacy@rwasport.rw` appears in the public privacy notice and on every roster form sent to a school, and must route to them.

6.4 Data protection impact assessment (art. 15)

Drafted. `privacy/DPIA.md` — purposes, necessity per field, eleven identified risks, the controls now in place against each, and residual risk.

Still needed. DPO review and controller sign-off (§7 of that document). Where residual risk stays high — R6, residency — art. 16 requires prior consultation with the NCSA.

6.5 Processor contracts (art. 49)

Prepared. `privacy/PROCESSORS.md` registers all six processors, what each holds, where, and the ten clauses a compliant agreement must contain.

Still needed. Signed agreements. The 48-hour processor-to-controller breach clause is the one standard terms usually miss, and it decides whether the controller can meet its own deadline.

6.6 Consent for athletes already registered

Now handled in the product. New registrations already refuse without consent, so this set only shrinks. For the historic records:

- `GET /akc3/admin/consent/backlog` — outstanding count per school.
- `GET /akc3/admin/schools/:id/consent-form` — a CSV pre-filled with exactly the children concerned, so nobody re-types a roster. Schools use `GET /akc3/school/consent-form` for their own.
- `POST /akc3/admin/consent/import` — applies the returned form. It only ever **updates** existing athletes, matches on athlete id, and refuses a row whose name no longer matches that id, on the assumption the form was re-sorted.
- Athletes awaiting consent are **withheld from published team sheets** until it arrives — art. 9 gives no basis to process, and publishing is processing.
- A row answering NO is recorded as a refusal and reported, so the record can be erased rather than left in limbo.

Still needed. Send the forms, chase them, and erase the records of any child whose guardian refuses or does not reply.

Penalties (arts. 53, 62–63): administrative fines of RWF 2–5 million or 1% of annual turnover; criminal fines up to 5% of turnover; asset seizure and closure.

7. Reviewing this

Re-read this document whenever a new field holding personal data is added, a new public endpoint is exposed, or a new processor is engaged. The table in §1 is only useful if it is true.